

1. Executive Summary

This report presents the findings of a simulated Red Team security assessment conducted to evaluate the security posture of a target organization. The objective of this engagement was to replicate real-world cyberattack scenarios using ethical hacking techniques and identify vulnerabilities across multiple stages of the cyber kill chain.

The engagement covered several phases including Open Source Intelligence (OSINT), reconnaissance, phishing-based initial access, vulnerability exploitation, lateral movement, persistence mechanisms, and data exfiltration. Various industry-standard security tools such as Recon-ng, Maltego, Shodan, Nmap, Metasploit, Impacket, and Mimikatz were used to simulate real attack techniques used by advanced threat actors.

The assessment demonstrated how attackers can gather intelligence from publicly available sources, exploit misconfigured systems, move laterally across networks, and maintain persistent access within compromised environments.

Key findings from the engagement indicate that exposed services, weak credential policies, and insufficient monitoring mechanisms significantly increase the risk of successful cyber intrusions. The report also provides recommendations for improving defensive strategies, including stronger authentication policies, network monitoring, patch management, and employee awareness training against phishing attacks.

Overall, this exercise highlights the importance of proactive security testing and the implementation of layered cybersecurity defenses to mitigate modern cyber threats.

2. Introduction

Cybersecurity threats continue to evolve rapidly, with attackers using increasingly sophisticated techniques to gain unauthorized access to organizational systems. Red Team engagements are conducted to simulate real-world cyberattacks and evaluate how effectively an organization can detect and respond to threats.

The purpose of this assignment was to perform a simulated Red Team operation covering the complete attack lifecycle. This includes reconnaissance, exploitation, lateral movement, persistence, and exfiltration of sensitive information.

The engagement also mapped the techniques used to the MITRE ATT&CK Framework, which provides a structured taxonomy of adversarial behaviors observed in real cyberattacks.

This report documents the methodology, tools, activities performed, observations, and security recommendations based on the simulated engagement.

3. Methodology

The Red Team engagement followed a structured attack framework similar to real-world adversary operations. The methodology consisted of the following phases:

Reconnaissance and OSINT

Initial Access

Exploitation

Lateral Movement

Persistence

Post-Exploitation

Data Exfiltration

Reporting and Analysis

Each stage was performed in a controlled lab environment using virtual machines and security tools.

4. OSINT and Reconnaissance

Reconnaissance is the first phase of an attack in which attackers gather information about the target without directly interacting with its systems. This process is also known as Open Source Intelligence (OSINT).

In this exercise, tools such as Recon-ng, Maltego, and Shodan were used to identify exposed systems and gather publicly available information.

Subdomain Enumeration

Recon-ng was used to discover subdomains related to the target domain.

Subdomain

IP Address

Notes

www.example.com◆

93.184.216.34

Main web server

mail.example.com

93.184.216.35

Mail service

dev.example.com

93.184.216.36

Development server

This information can be used by attackers to identify additional entry points into the network.

Shodan Search

The Shodan search engine was used to identify exposed internet-connected systems.

Query used:

apache country:US

Results showed several publicly accessible Apache servers that could potentially contain vulnerabilities if not updated properly.

Summary (50 words)

Shodan results revealed multiple internet-facing Apache servers running outdated versions of web software. These exposed hosts could potentially be vulnerable to known exploits if not patched. Public exposure of services significantly increases the attack surface and allows attackers to identify potential targets for exploitation.

5. Phishing Simulation

Phishing is one of the most common methods used by attackers to gain initial access to systems.

In this simulation, Gophish and Evilginx2 were used to replicate a credential harvesting attack.

Campaign Setup

A phishing campaign was created using a cloned login page that mimicked a legitimate website login portal.

Users who accessed the page and entered credentials had their information captured in the phishing server.

Credential Capture Log

Timestamp

IP Address

Username/Password

Risk

Notes

2025-08-29 12:00

192.168.1.50

testuser/pass123

High

Credentials successfully captured

This demonstrates how easily attackers can obtain login credentials using social engineering techniques.

6. Vulnerability Exploitation

After gaining initial access, attackers attempt to exploit vulnerabilities in systems to escalate privileges or execute malicious code.

Tools used in this phase:

Nmap

Metasploit

OWASP ZAP

Network Scanning

Nmap was used to scan the target system for open ports and running services.

```
nmap -sV 192.168.1.10
```

This scan identified several services that could potentially be exploited.

Vulnerability Findings

Vulnerability

CVSS Score

Description

Apache Struts RCE

9.8

Remote code execution vulnerability

Weak SMB Configuration

8.1

Allows unauthorized access

Exploitation

Metasploit was used to exploit the Apache Struts vulnerability and gain remote shell access to the system.

7. Lateral Movement and Persistence

Once attackers gain access to a system, they attempt to move laterally within the network to compromise additional machines.

Tools used:

Impacket

Covenant

Lateral Movement

The psexec.py module from Impacket was used to execute commands on remote systems.

Summary (50 words)

After initial compromise, lateral movement was simulated using Impacket's PsExec tool. The compromised credentials were used to authenticate to another system within the network.

This allowed the attacker to gain control over additional machines, demonstrating how a single compromised account can lead to broader network compromise.

Persistence Mechanism

A scheduled task was created to ensure persistent access to the system.

Technique

Tactic

Description

Notes

Scheduled Task

Persistence

T1053

Executes payload daily

Persistence mechanisms allow attackers to maintain access even if the system is restarted.

8. Social Engineering Simulation

Social engineering involves manipulating individuals to reveal confidential information.

Tools used:

PhoneInfoga

Maltego

Social Engineering Toolkit (SET)

Intelligence Gathering

PhoneInfoga was used to collect information related to the target phone number.

Target ID

Data Source

Information

Notes

TID001

PhoneInfoga

Phone: 555-1234

Linked to target

Vishing Scenario Summary (50 words)

A simulated vishing attack was conducted where the attacker impersonated an IT support representative and requested the user to verify account credentials due to a supposed system update. This scenario demonstrates how attackers exploit trust and urgency to trick individuals into revealing sensitive information.

9. Exploit Development Basics

Basic binary analysis was performed to understand how vulnerabilities such as buffer overflows occur.

Tools used:

GDB

radare2

Binary Analysis Findings (50 words)

Initial analysis of the vulnerable program revealed unsafe input handling functions such as gets() that do not validate input length. This allowed an attacker to overflow the buffer and overwrite memory locations. Such vulnerabilities can lead to arbitrary code execution and compromise of the target system.

10. Post-Exploitation and Data Exfiltration

After gaining administrative privileges, attackers often attempt to collect sensitive data.

Tools used:

Mimikatz

DNS tunneling utilities

Credential Dumping

Mimikatz was used to extract password hashes from memory.

Hash Type

Username

Hash Value

NTLM

Administrator

aad3b435b51404eeaad3b435b51404ee

Data Exfiltration

Sensitive data was exfiltrated using DNS tunneling techniques to bypass firewall restrictions. This technique allows attackers to transmit data through DNS requests, which often go unnoticed in many networks.

11. Blue Team Detection Analysis

The system logs were reviewed to determine whether defensive mechanisms could detect the simulated attack.

Timestamp

Alert Description

Source IP

Notes

2025-08-29 13:00

Suspicious Login Attempt

192.168.1.50

Phishing attempt detected

The logs showed several suspicious authentication attempts, which could alert security analysts.

However, improved monitoring and behavioral analytics are required for faster detection.

12. Attack Flow Overview

The overall attack followed the sequence below:

Reconnaissance → Initial Access → Exploitation → Lateral Movement → Persistence → Credential Dumping → Data Exfiltration

This attack chain closely resembles techniques used by real threat actors and aligns with the MITRE ATT&CK framework.

13. Security Recommendations

Based on the findings of the simulated Red Team engagement, the following security improvements are recommended:

Implement Multi-Factor Authentication (MFA) to prevent credential-based attacks.

Regularly update and patch software to mitigate known vulnerabilities.

Deploy advanced Endpoint Detection and Response (EDR) solutions.

Conduct employee cybersecurity awareness training to reduce phishing success.

Monitor network logs using Security Information and Event Management (SIEM) systems.

Restrict unnecessary services and close unused ports.

Implement network segmentation to limit lateral movement.

14. Conclusion

This simulated Red Team engagement demonstrated how attackers can exploit publicly available information, weak security controls, and vulnerable systems to gain unauthorized access and move laterally within a network.

The exercise highlighted the importance of proactive security testing, strong authentication mechanisms, system monitoring, and employee awareness in defending against cyber threats.

Organizations must adopt a defense-in-depth approach to cybersecurity by combining technical controls, policies, and continuous monitoring to reduce the risk of successful cyberattacks.

Regular Red Team assessments and penetration testing exercises are essential to identify weaknesses before they can be exploited by malicious actors.